

Lab: SSRF with whitelist-based input filter

1. Chi tiết bài lab

Mục tiêu của bài lab là khai thác lỗ hổng Server-Side Request Forgery (SSRF) bằng cách vượt qua cơ chế kiểm tra danh sách trắng (whitelist) của ứng dụng. Sau khi bypass thành công, truy cập vào giao diện quản trị nội bộ (Admin Interface) và xóa tài khoản người dùng carlos.

2. Trả lời câu hỏi

What is Server-Side Request Forgery (SSRF), and how does it differ from other types of web application vulnerabilities?

→ SSRF (Server-Side Request Forgery) là một lỗ hổng bảo mật cho phép kẻ tấn công lợi dụng máy chủ để gửi các yêu cầu HTTP đến những địa chỉ do chúng chỉ định. Thông qua lỗ hổng này, kẻ tấn công có thể truy cập các dịch vụ nội bộ, giao diện quản trị hoặc lấy thông tin nhạy cảm mà người dùng bên ngoài không thể truy cập trực tiếp. Khác với SQL Injection, vốn khai thác cơ sở dữ liệu, hay Cross-Site Scripting (XSS), vốn thực thi mã JavaScript trên trình duyệt của người dùng, SSRF nhắm trực tiếp vào máy chủ và lợi dụng khả năng giao tiếp của máy chủ với các hệ thống khác để vượt qua các biện pháp bảo vệ như tường lửa hoặc giới hạn truy cập mạng.

Describe a methodology for exploiting an SSRF vulnerability in a web application.

What are the key steps and techniques involved in crafting and sending malicious requests to exploit SSRF vulnerabilities?

→ Quy trình khai thác SSRF thường bắt đầu bằng việc xác định các tham số đầu vào mà ứng dụng sử dụng để gửi yêu cầu đến một URL, sau đó sử dụng Burp Suite để chặn và chỉnh sửa request. Tiếp theo, kẻ tấn công thay đổi URL thành các địa chỉ nội bộ như 127.0.0.1 hoặc localhost để kiểm tra xem máy chủ có thực hiện request thay người dùng hay không. Nếu ứng dụng có cơ chế bảo vệ như whitelist hoặc blacklist, có thể áp dụng các kỹ thuật bypass như URL Encoding, Double URL Encoding, Embedded Credentials (username@hostname) hoặc các cách biểu diễn địa chỉ IP khác nhau để vượt qua bộ lọc. Sau khi bypass thành công, máy chủ sẽ gửi request đến các tài nguyên nội bộ như giao diện quản trị hoặc API nội bộ, cho phép kẻ tấn công truy cập hoặc thực hiện các thao tác trái phép. Việc khai thác được xác nhận khi truy cập được tài nguyên nội bộ hoặc hoàn thành mục tiêu của bài kiểm thử, chẳng hạn như xóa tài khoản người dùng trong môi trường lab.

3. Chi tiết lab

B1. Truy cập vào một sản phẩm bất kỳ và nhấn Check stock. Request được Burp Suite chặn lại thông qua Proxy, sau đó gửi sang Repeater để chỉnh sửa và kiểm tra.

kali-linux-2025.3-vmware-amd64 - VMware Workstation

File Edit View VM Tabs Help

Home kali-linux-2025.3-vmware-amd64

Lab: SSRF with whitelist

SSRF with whitelist-based input filter

https://0a1600570431607f853162b7009500ab.web-security-academy.net

WebSecurity Academy

SSRF with whitelist-based input filter

LAB Not solved

Back to lab description >

Home | My account

WE LIKE TO SHOP



High-End Gift Wrapping
★★★★★ \$70.57
View details



3D Voice Assistants
★★★★★ \$46.43
View details



Pest Control Umbrella
★★★★★ \$8.58
View details



Baby Minding Shoes
★★★★★ \$25.72
View details



To direct input to this VM, move the mouse pointer inside or press Ctrl+G.

Search

4:04 PM 7/1/2026

kali-linux-2025.3-vmware-amd64 - VMware Workstation

File Edit View VM Tabs Help

Home kali-linux-2025.3-vmware-amd64

Lab: SSRF with whitelist

SSRF with whitelist-based input filter

https://0a1600570431607f853162b7009500ab.web-security-academy.net/product?productId=3



Description:

We recently discovered, by accident, that vermin and all manner of pets and pests are attracted to umbrellas. Not to just any umbrellas though, they have to be long, pointy ones.

It is very hard these days to get hold of an umbrella that isn't collapsible, these will not work as pest control. So, we decided to start designing and manufacturing our unique Pest Control Umbrella, the only genuine umbrella that will do the job. We have all copyright on these brollies and no other companies are allowed to remotely hint that their umbrellas can be used to rid yourself of those pesky pests.

Never knowingly undersold we guarantee a price match on any other form of pest control, but not if you use a different umbrella for the job.

London

Paris

Milan

Paris

and facing behind you and watch the creatures follow your lead. By purchasing this highly effective product you will rest control business, a little investment now will pay great dividends in the future for you and your family.

Check stock

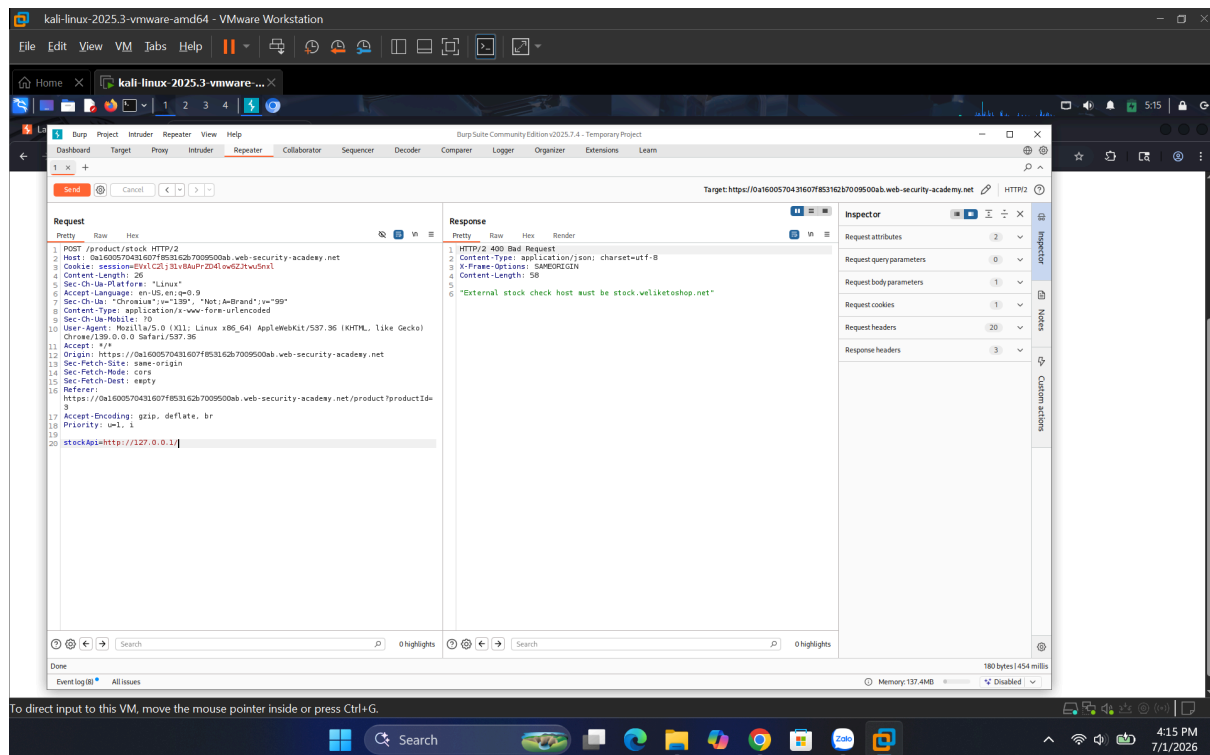
< Return to list

To direct input to this VM, move the mouse pointer inside or press Ctrl+G.

Search

4:04 PM 7/1/2026

Sau khi gửi request, máy chủ từ chối truy cập. Điều này cho thấy ứng dụng đang kiểm tra tên miền và chỉ cho phép các địa chỉ nằm trong danh sách trắng.

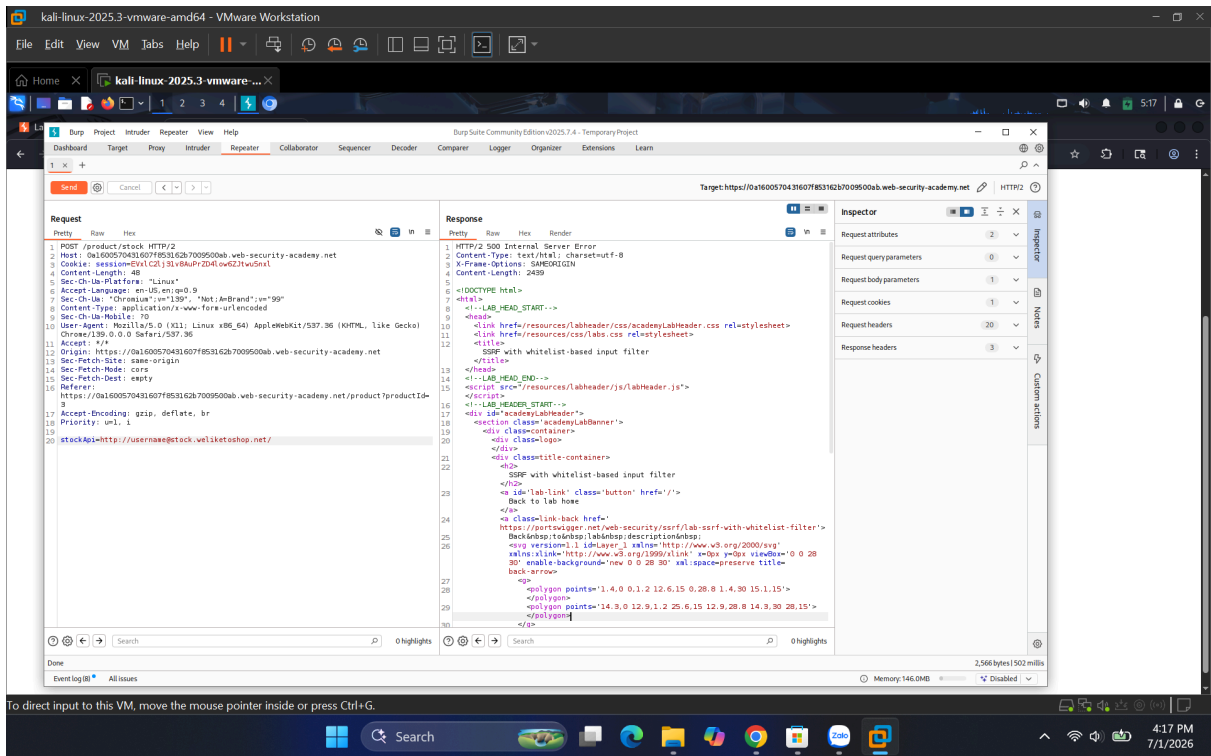


B3. Kiểm tra Embedded Credentials

Tiếp tục sửa URL thành:

http://username@stock.weliketoshop.net/

Request được chấp nhận, chứng tỏ trình phân tích URL của ứng dụng hỗ trợ phần embedded credentials (username@hostname) và chỉ kiểm tra phần hostname để xác thực.

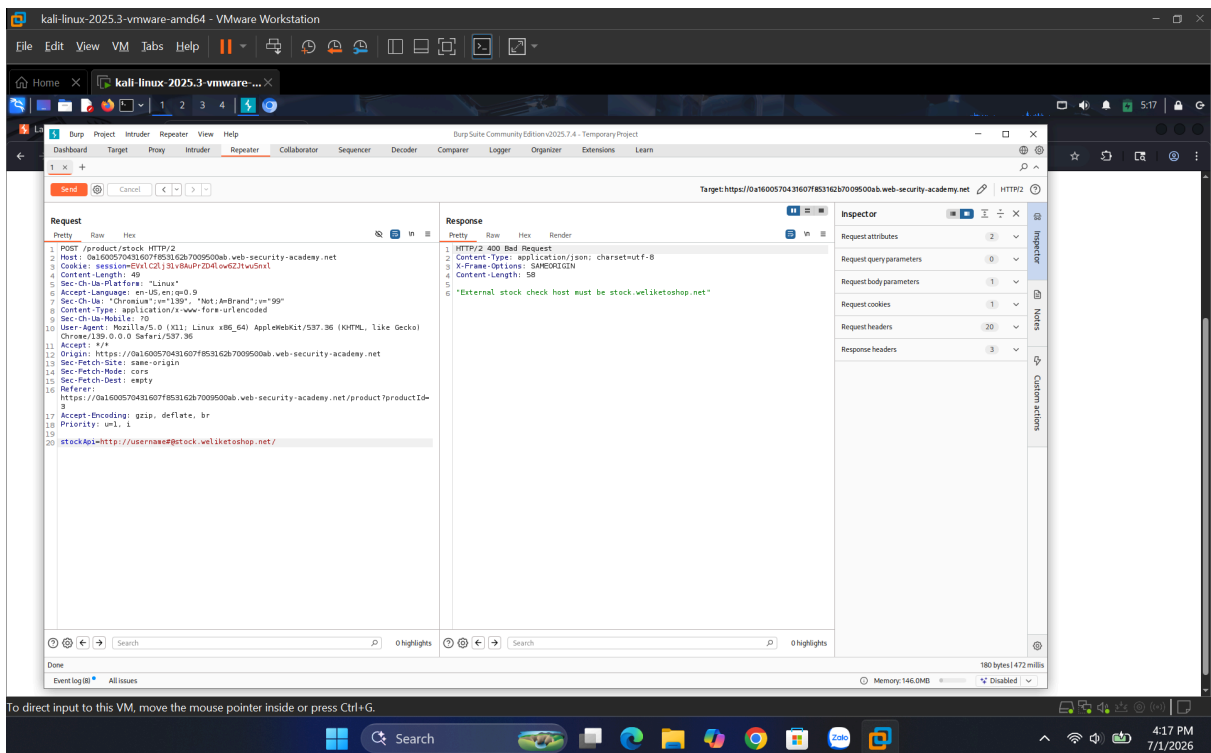


B4. Kiểm tra ký tự

Thêm ký tự # vào URL:

<http://username#@stock.weliketoshop.net/>

Request bị từ chối vì ký tự # được trình phân tích URL hiểu là bắt đầu của phần fragment.

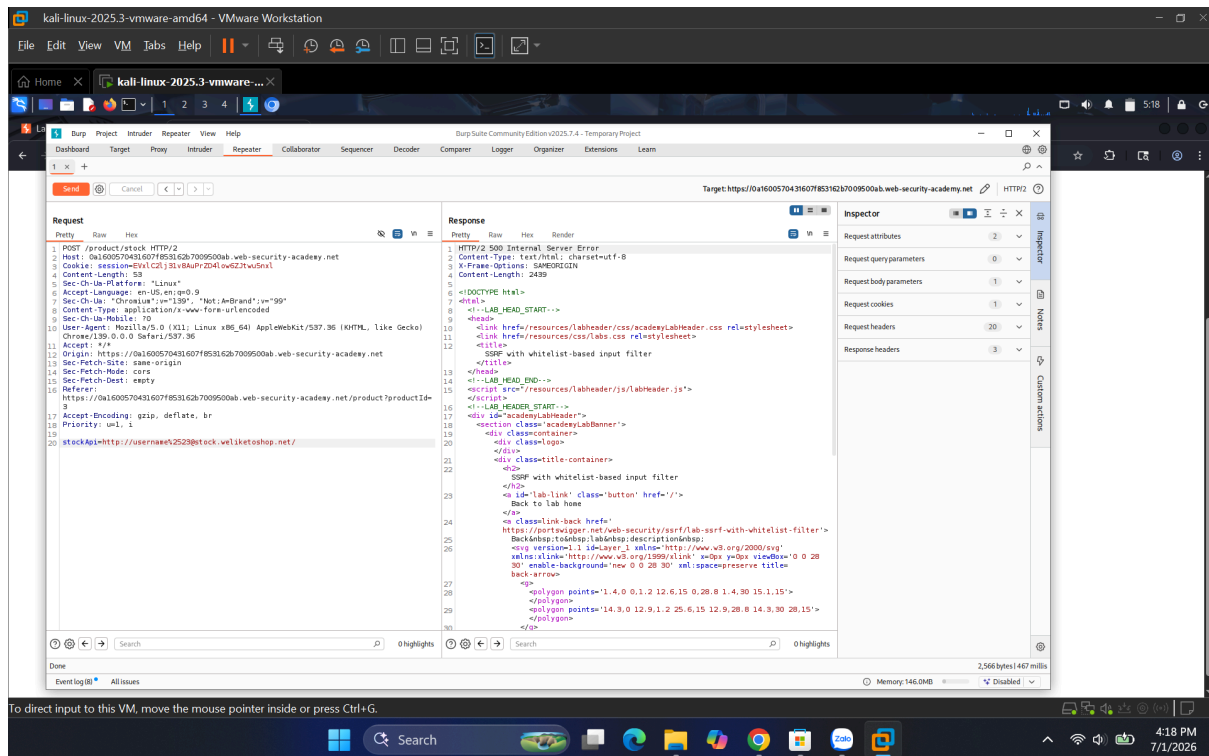


B5.Double URL Encode

Thay ký tự # bằng giá trị mã hóa hai lần %2523:

<http://username%2523@stock.weliketoshop.net/>

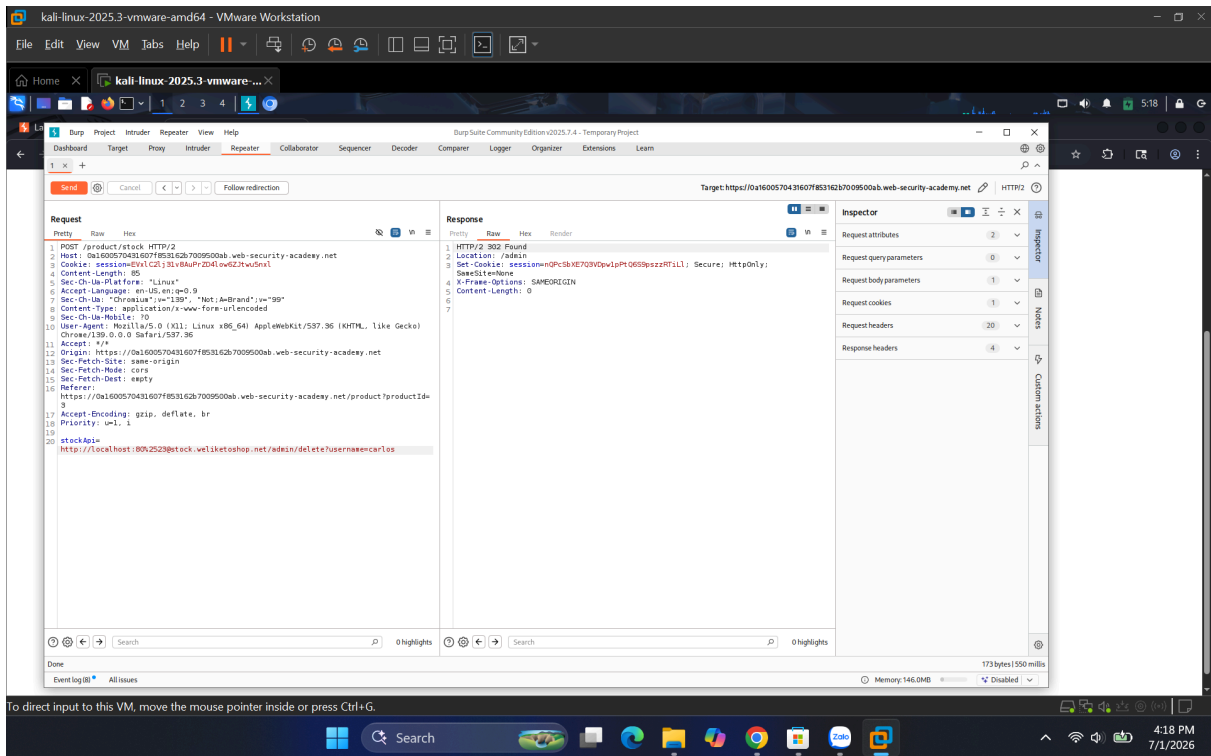
Sau khi gửi request, máy chủ trả về lỗi 500 Internal Server Error. Điều này cho thấy URL đã được giải mã ở giai đoạn xử lý phía máy chủ và có sự khác biệt giữa quá trình kiểm tra URL và quá trình thực hiện kết nối.



B6. Thay đổi URL thành:

<http://localhost:80%2523@stock.weliketoshop.net/admin/delete?username=carlos>

Request được gửi thành công. Do sự khác biệt trong cách xử lý URL, bộ lọc whitelist vẫn cho phép vì nhìn thấy hostname là stock.weliketoshop.net, trong khi máy chủ thực tế lại kết nối tới localhost và truy cập đường dẫn `/admin/delete?username=carlos`. Kết quả là tài khoản carlos đã bị xóa thành công.



B7. Thành công

